Richard Mahmud-Okhai

Encryption/Cryptography – Password Secure Vault

October 21, 2026

Independent Security Research

Disclaimer: Copying or downloading this file without authorization is prohibited and illegal

TABLE OF CONTENTS

Purpose: 3

Overview: 4

Product Demonstration: 5

Security Evaluation: 9

Business Model/SWOT Analysis: 13

Disclaimer: Copying or downloading this file without authorization is prohibited and illegal

PURPOSE

The importance of password security has grown exponentially in this fast-growing industry – Ranging from critical infrastructures to public sectors. Issues with password leakage and account compromise originates from the mis-safeguard of password/credentials to sensitive web portals and software applications. Multiple defense in-depth techniques have been recommended by the NSA/DoD and other government agencies – Defense in-depth such as multi-factor authentication, alongside the use of a proprietary solution is also wildly utilized in most organizations for password secure vaulting.

A proprietary solution will provide all adequate needs, including but not limited to remote desktop support and automated password/key rotation within the on-premises and cloud or hybrid environment. The main question is, what if my organization cannot afford a proprietary solution, or a backup solution is needed for highly secure applications? The answer to this is a home-grown solution written in any programming language of choice and bits of database design and architecture, alongside a great deal of knowledge in technology and engineering for computing and network architecture. But the best part of a home-grown solution is how an organization has the autonomy to use any cryptographic algorithm of choice such as AES for symmetric and ECC for asymmetric with custom design established and outlined by the organization research and development team. The best part of a home-grown solution is also the safeguard of credentials on an isolated server in a secure datacenter designed to provide the needed autonomy to a platform as a service, as well as an infrastructure as a service - Compared to a Software as a Service solution that utilizes third party or managed provider to safeguard both infrastructure and platform for a product.

Nevertheless, the purpose of this solution is to provide a secure technology to help safeguard sensitive account credentials for software applications and web portals maintained and owned by an organization. The benefit of owning a solution such as the Key-Vault for password secure vaulting is to provide a backup solution to secure credentials for web and application portal, as well as limiting access to this sensitive data to strictly technical personnel of the organization with necessary clearance and approval

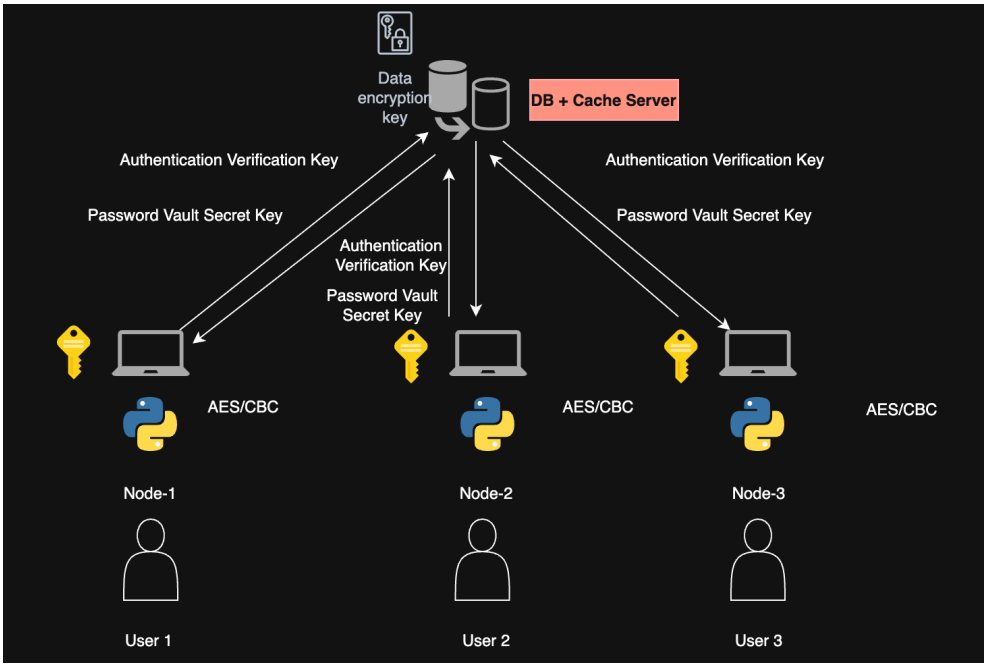
Disclaimer: Copying or downloading this file without authorization is prohibited and illegal

by the organization leader. Trust, reliability, accessibility, and cost-effective are the main purpose of the design and implementation of the password secure vault for Key-Vault.

OVERVIEW

Key-Vault is designed for the use of password secure vault only, and limitations to remote desktop and automated password rotation is/and will be limited but can be implemented by design. Manual key rotation and authentication alongside account set-up will be conducted strictly by an engineer or a developer to limit access to the sensitive data on the database server. Technology behind the design is complex and requires a great deal of experience in technology and engineering for a thorough implementation of the product, with the use of two cryptographic algorithm + hashing & salting to provide good security layer and isolation of data in the vault engine to only individuals with valid access. The overall structure and packaging of the product requires a good knowledge in software devops, security engineering & architecture, database design & engineering, alongside wireless network security. For simplicity, each individual secret key will be concealed and packaged into one zip-file to be installed and executed on individual host.

Figure 1.0: Key-Vault Overview



Disclaimer: Copying or downloading this file without authorization is prohibited and illegal

In addition, majority of the functions utilized for the product designed is open-source, within an on-premises infrastructure (compatible with cloud solutions). In the product demonstration section for this research paper, an infrastructure diagram will be show-cased detailing the implementation and the use-case for the product designed.

A great advantage of the product designed overall is an additional security layer that aligns with both availability, integrity and confidentiality of the CIA triad principle. Also, alignment with the ISO 27001 A.8.24 framework for confidentiality with the use of encryption for data-at-rest, and encryption for data-in-transit is also included in the product designed. In addition to the security features, included in the product is also a custom design that mask the password to a certain vault account during data-in-use. The overall product is designed for overt channel to secretly and securely transport a credential from a specific endpoint to a secure vault engine, as well as to retrieve the credentials securely over-the network from a vault engine.

PRODUCT DEMONSTRATION

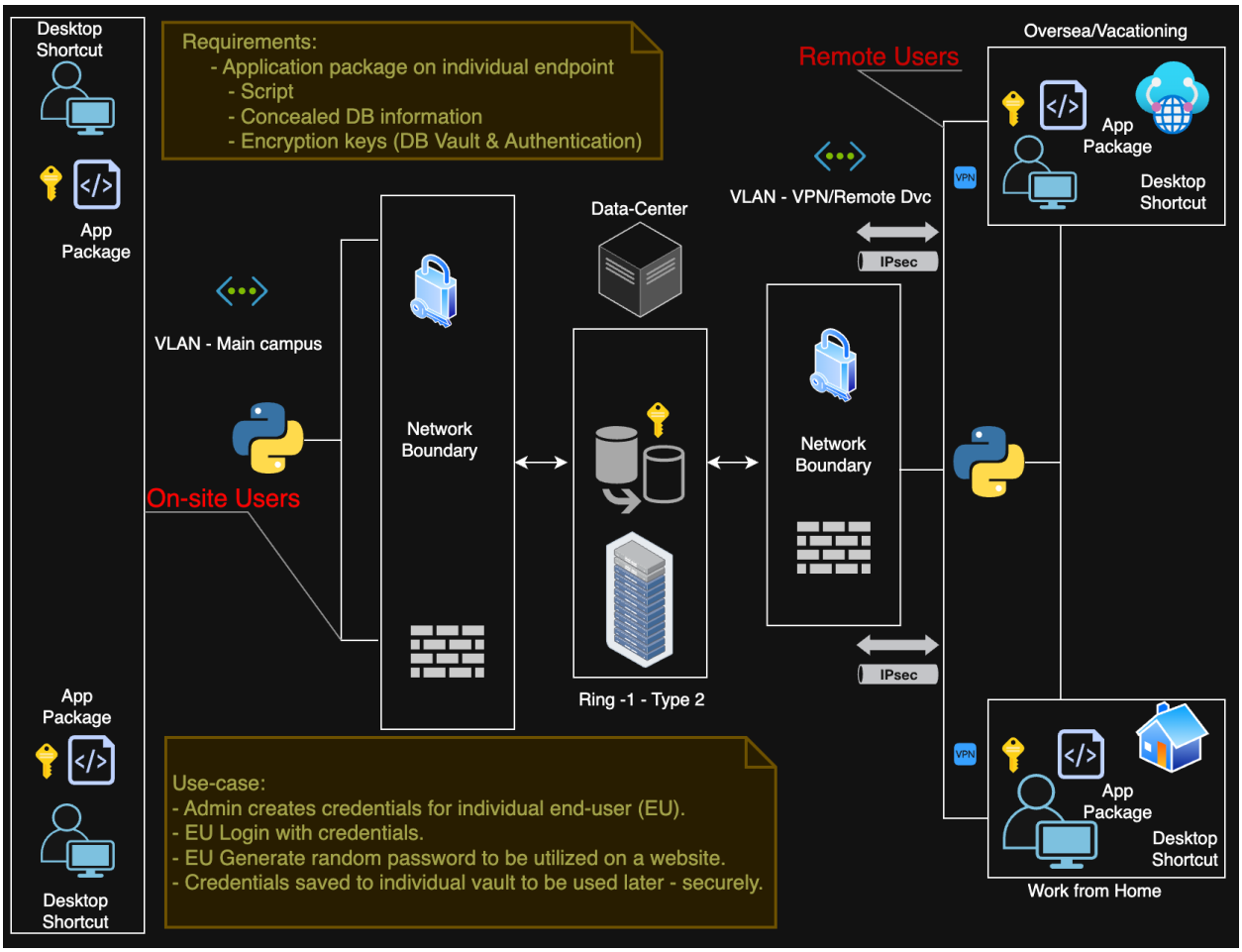
An overall understanding of the product designed is to ensure data stored in a vault engine is only accessible to the secret key assigned to the subject key-vault for the saved credentials (Clark-Wilson Model) – Any other secret key utilized for password retrieval will be restricted or denied. In addition to this design is also a key security feature that gives an upper-hand to a super administrator for retrieval of a credential (but cannot modify a credential associated to a primary or secret key) during a data-recovery process or a disaster/technical event impacting an endpoint associated to a key or the vault engine as a whole (Bella-Lapadula Model). An overall security feature restricting the use of same subject-id for a vault account is also in-play for account created by an admin (Brewer & Nash Model) – For example, a subject-id created as user3 with an assigned primary key cannot be recreated for another subject. This address an issue with conflict of interest with account created within the vault engine.

Infrastructure utilized for this product is strictly on-premises with a database/vault engine in a separate data-center accessible at any location with the right network requirements. Node/endpoint with the right network access either via a VPN or an on-site network connection with limited port restriction to the

Disclaimer: Copying or downloading this file without authorization is prohibited and illegal

vault engine should be allowed to retrieve credentials saved in a vault engine associated to a secret and primary key of a legitimate endpoint (see figure 2.0).

Figure 2.0: *Vault Design – On-premises Infrastructure*



Product Use-Case:

Within the on-premises infrastructure, an endpoint was acquired and utilized for a use case demonstrated in the scenario below. One of the problems addressed is the re-use of a subject credential pertaining to a home-grown application within the vault engine for a primary/secret key – Administrators are very strict on password re-use and password vaulting within a critical infrastructure or a highly secure organization. Most cases, users utilize the same password for over 10-20 applications on a web browser credential vault. The use of browser credential vault comes with a security concern should a malicious site is

Disclaimer: Copying or downloading this file without authorization is prohibited and illegal

visited, or a malicious browser extension is in-use, all the password vaulted within the web browser will and might be compromised. Also, an endpoint infected with a malware designed as a command and control can illegitimately retrieve any saved plaintext credential on an endpoint. Encryption at host for password vaulting is designed to address all the outlined security issues.

Scenario 1:

An end-user contacted the service desk regarding the use of password vaulting. An administrator was assigned to this ticket, and a call was made to the end-user to gather user requirement. Once requirement is gathered, a ticket was created for DevOps to package and create a secret key for password vaulting for node 3. Technical support retrieves the zipped file to be securely transported on layer 4 to the endpoint alongside a separate script to generate and auto assign a key to a node. Folder was unzipped and file was executed with a desktop shortcut created for user 3 on node 3.

- **Vault account created by an administrator**

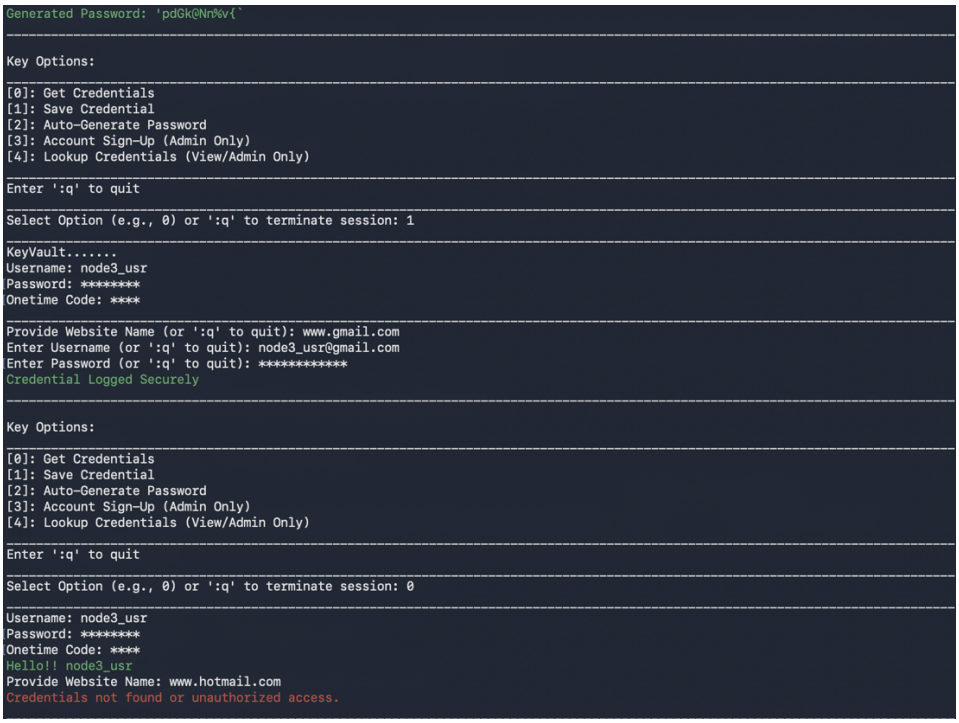
```
Connecting........
Finalizing Connection..........
Connection Successful
_____________________________________________________________________________________________________________________
Session Active: 2026-10-21 18:13:40
_____________________________________________________________________________________________________________________

Credential Vault
_____________________________________________________________________________________________________________________
_____________________________________________________________________________________________________________________

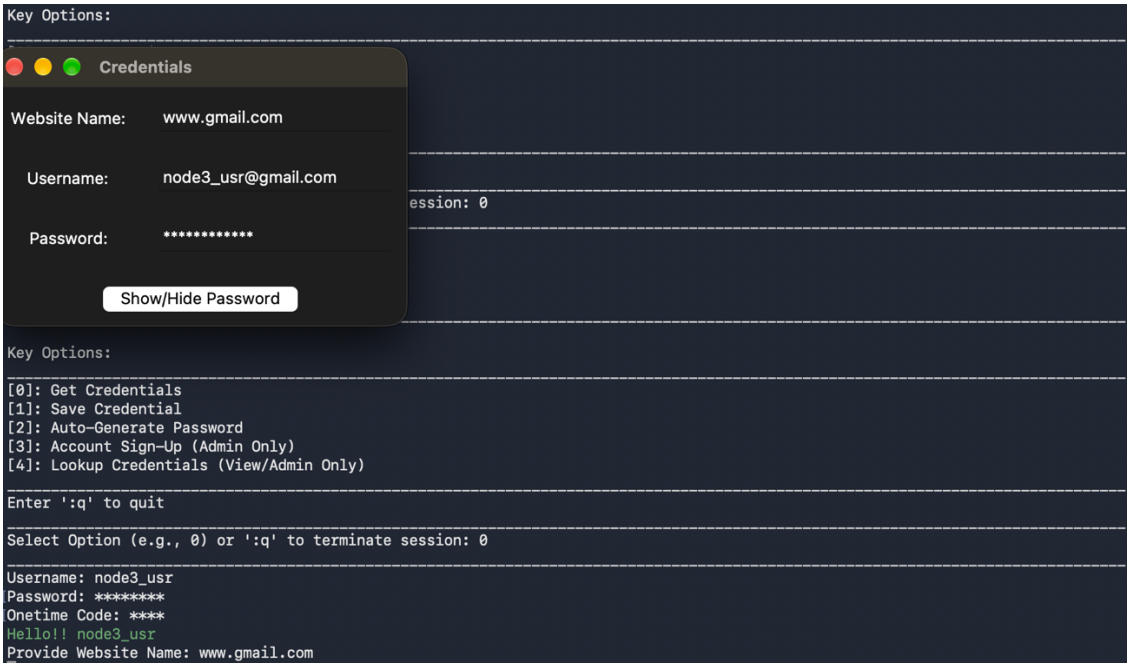
Key Options:
_____________________________________________________________________________________________________________________
[0]: Get Credentials
[1]: Save Credential
[2]: Auto-Generate Password
[3]: Account Sign-Up (Admin Only)
[4]: Lookup Credentials (View/Admin Only)
_____________________________________________________________________________________________________________________
Enter ':q' to quit
_____________________________________________________________________________________________________________________
Select Option (e.g., 0) or ':q' to terminate session: 3
_____________________________________________________________________________________________________________________
Welcome - Admin Authentication Required:
Username: rmoadmin
Password: *********
Onetime Code: ****
Login Successful - Create New KeyVault Account
_____________________________________________________________________________________________________________________
Enter New Username: node3_usr
Enter New Password: ********
Enter New Onetime Code: ****
_____________________________________________________________________________________________________________________
Vault Account Successfully Created.
_____________________________________________________________________________________________________________________
```

Disclaimer: Copying or downloading this file without authorization is prohibited and illegal

- **Vaulted credential with user 3 secret key utilized. Restrictions applied on saved credentials not associated to the primary/secret key of node 3.**



- **Valid credential associated to node 3 primary/secret key retrieved.**



Disclaimer: Copying or downloading this file without authorization is prohibited and illegal

SECURITY EVALUATION

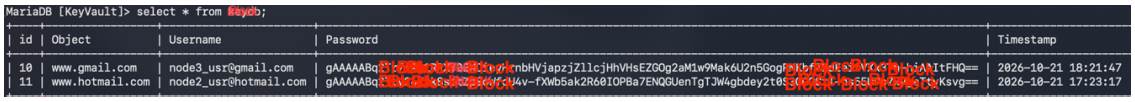
Security evaluation for product utilized for safeguarding or protecting sensitive information should undergo security review to outline areas that best describe the use of the product to provide assurance to the product user/owner. In most cases, evaluation is conducted on an annual basis with continuous evaluation dedicated to the overall product in-use and the environment it runs on. But for a product implemented within a DEV environment - to showcase the importance of security such as the importance of safeguarding sensitive data for key-vaulting, a quick outline on how the sensitive data is protected at rest, in transits, and in-use are outlined below:

- **Protection-at-rest:** Provides protection for secret or sensitive data such as credentials in the vault engine while at rest.
    - **Polyinstantiation:**
        - During a situation when a user to an authorized endpoint is unable to retrieve a credential but most certain it exists in the vault engine – Only an admin can retrieve this information for the user due to limited access to the password vault for all secrets in the vault engine. This address an issue with polyinstantiation that enables end-user to view all credentials associated to an endpoint within a vault engine.



Disclaimer: Copying or downloading this file without authorization is prohibited and illegal

- **Key Management:**
  - Symmetric encryption utilized with cipher-block-chaining to make distribution and key re-use by an unauthorized entity impossible.

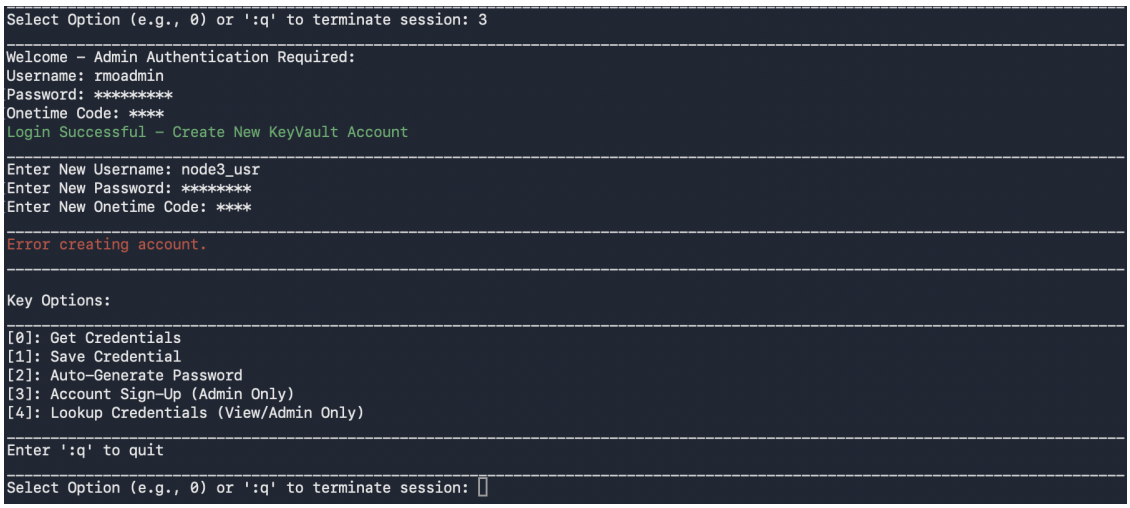


```
MariaDB [KeyVault]> select * from keydb;
+----+-----------------+-----------------------+------------------------------------------------------------------------------------------------------------------------------------------------------------------------+---------------------+
| id | Object          | Username              | Password                                                                                                                                                               | Timestamp           |
+----+-----------------+-----------------------+------------------------------------------------------------------------------------------------------------------------------------------------------------------------+---------------------+
| 10 | www.gmail.com   | node3_usr@gmail.com   | gAAAAABq[redacted]nbHVjapzjZllcjHhVHsEZGOg2aM1w9Mak6U2n5Gog[redacted]ItFHQ==                                                                                            | 2026-10-21 18:21:47 |
| 11 | www.hotmail.com | node2_usr@hotmail.com | gAAAAABq[redacted]V4v-fXWb5ak2R60IOPBa7ENQGUenTgTJW4gbdey2t0[redacted]Ksvg==                                                                                            | 2026-10-21 17:23:17 |
+----+-----------------+-----------------------+------------------------------------------------------------------------------------------------------------------------------------------------------------------------+---------------------+
```

  - Each key is associated to an endpoint, and a subject-id cannot be reused by another endpoint with another subject-id.
  - Key rotation can be initiated but will need to be re-associated with a subject primary key within the vault engine.
  - Authentication is done by hashing in SHA256 and salting on the vault engine to make it impossible for rainbow table or brute-force attack in very rare occasion when/if the vault engine is compromised.
- **Cryptographic Algorithm (Vault Database):**
  - **Symmetric:**
    - Great for encryption for data at rest.
    - Keys are not shared and a single key is utilized to decrypt information in the vault engine but associated to an endpoint or a subject foreign key.
    - Faster for bulk encryption/decryption should there be a situation where multiple subjects need to access the vault engine at a time.
- **IDS/IPS Sensor:**
  - Keys are encrypted on each endpoint and concealed within the application package. An IDS or an IPS will restrict access to the key on the endpoint should there be any issue with a compromised engine by an unauthorized subject or an object.

Disclaimer: Copying or downloading this file without authorization is prohibited and illegal

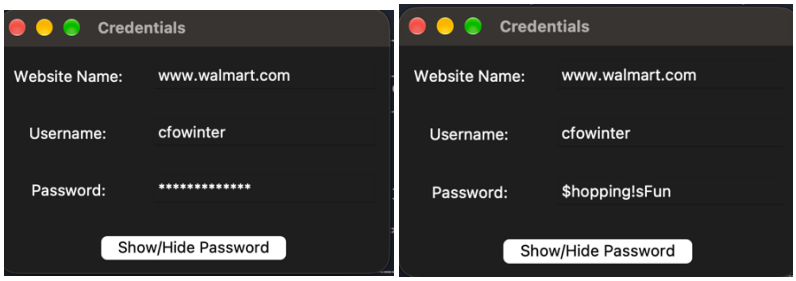
- **Protection-in-transit:**
  - **Authentication/Verification (Key-Exchange – Endpoint<-> Vault Engine):**
    - Key-Vault account setup comprises of two scheme – A plaintext password entered by an admin during registration phase, and a hashed/salted password within the vault engine. Password authentication alongside a onetime code utilized during user set up also aligns well with the overall scope of the product. When a vault user attempts to authenticate into the vault engine, a plaintext credential entered within a concealed interface is utilized, but verification is done against the hashed algorithm of the password provided.
  - **Collision Resistance:**
    - Collision Resistance is also provided should same password is utilized for multiple accounts; this will be restricted within the vault engine and user account will not be created or accepted till a different subject-id/password is utilized.



- **Protection-in-use:**
  - **Masking:**
    - During the use of a password in a vault engine on an authorized endpoint, the user is provided an option to reveal a password masked within the program interface – A

Disclaimer: Copying or downloading this file without authorization is prohibited and illegal

revealed password will be hidden after a certain threshold to provide a great layer of protection during data-at-use.



- **Network Isolation:**
  - Vault engine is restricted to strictly on-premises access only – User with authorized access to the VPN can also access a vault engine but must be on the same network or an authorized network as the vault engine. The purpose of the product designed is to provide extra layer of protection for highly sensitive credentials for highly sensitive application developed and designed for home-grown use.

- **Firewall:**
  - During a legitimate request for a vault account for password/key-vaulting, a request is created and reported to the network team for access to the database engine on a unique port.

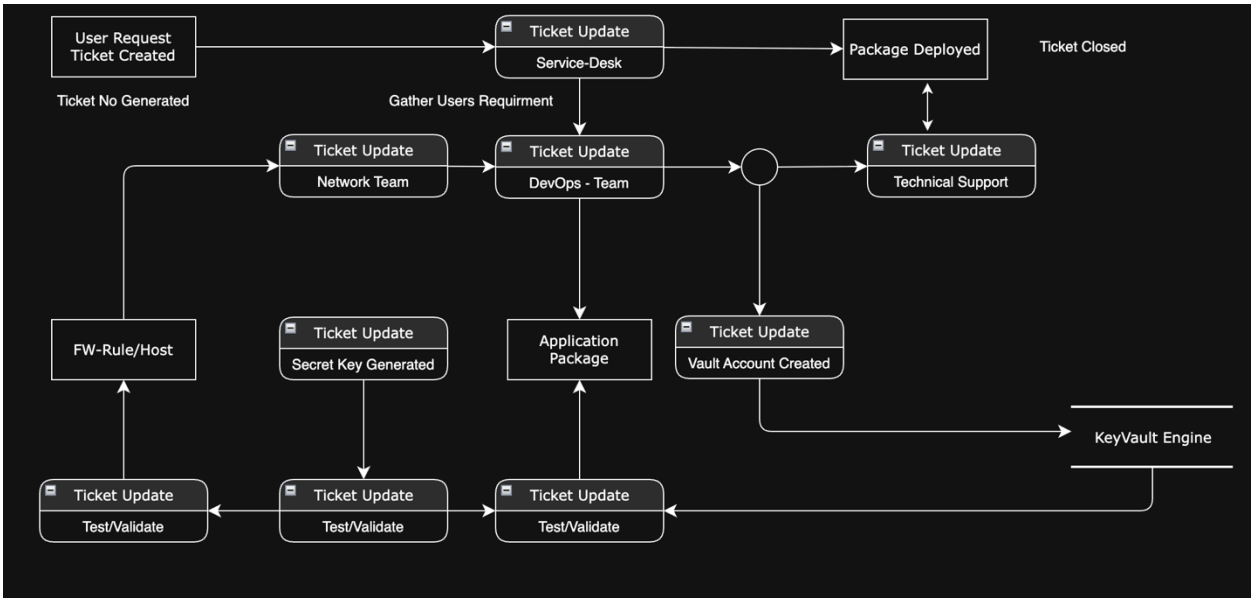
Scroll down to the next page

Disclaimer: Copying or downloading this file without authorization is prohibited and illegal

BUSINESS MODEL/SWOT ANALYSIS

Business model/process utilized for this use-case in operationalizing the product in-use is closely coupled with the *spiral model*. The spiral model approach explains the unique phases associated to each request which are aligned below alongside the relationship it has with password secure vaulting deployment process.

Figure 3.0: Spiral Model – Password Secure Vaulting Deployment Process



Planning/End-User Requirement

- **Ticket Request Overview:** End-user is contacted to outline the product limitation and overall process and timeline it'll take for full deployment. Also, requirements are gathered such as work devices utilized (OS, Device Type, etc.).

Deployment Analysis

- **Deployment Scope:** DevOps team collaborates with the security/network team, as well as technical support on the overall process and timeline for each individual task for the overall accomplishment or fulfilment of end-user's request. This includes but not limited to:

Disclaimer: Copying or downloading this file without authorization is prohibited and illegal

- **Test and Validate**:
  - Encryption keys
  - FW Rule
  - IDS/IPS exclusions and installations
  - And other necessary validation

Product Implementation

- **Product Package and Deployment:** Once requirement gathered (technical and non-technical requirements) are fulfilled, the DevOps team package an individual application package for password secure vaulting to be handed over to the technical support for endpoint deployment.

End-User Evaluation

- **Test and Evaluate:** Product is tested and evaluated by end-user if it meets requirements and overall business need for password secure vaulting. An account is created into the vault engine in this process during an active session with the technical support team. Feedback and evaluation are written in the ticketing system for the request to be sent to the research and development team.

Swot Analysis



Disclaimer: Copying or downloading this file without authorization is prohibited and illegal